

IT and Data Security Policy

Document Code: IT-POL-03 | Version: 3.0 | Effective Date: 1 October 2025 | Owner: Human Resources / IT Department

1. Password and Authentication Standards

- Minimum password length: 12 characters, including at least one number and one special character.
- Passwords must be rotated every 90 days and may not repeat the previous 5 passwords.
- Multi-factor authentication (MFA) is mandatory for all systems, including email, VPN, and internal tools.
- Shared or generic login credentials are prohibited except for approved service accounts registered with IT Security.

2. Data Classification

Classification	Examples	Handling Rule
Public	Marketing material, published blog posts	No restrictions
Internal	Internal memos, org charts, non-sensitive reports	Visible to employees only
Confidential	Contracts, source code, financial forecasts	Need-to-know basis; encrypted storage required
Restricted	Customer PII, payment data, employee salary data	Do not leave company-managed devices or systems; access limited

3. Device and Access Policy

Access to production systems and Restricted data is permitted only from company-issued, encrypted laptops enrolled in the corporate Mobile Device Management (MDM) platform. Personal devices (BYOD) may be enrolled in MDM for email and calendar access only, and may never be used to access Confidential or Restricted data.

4. Security Incident Reporting

Any suspected security incident — including lost devices, phishing attempts, unauthorized access, or suspected data breach — must be reported to security@nimbustech.example within 1 hour of discovery. The Security Operations team targets containment of confirmed incidents within a 4-hour Service Level Agreement (SLA) from the time of report.

5. Data Retention

System access logs are retained for 180 days. Full system backups are retained for 1 year on encrypted, offsite storage. Customer data deletion requests are processed within 30 days in

accordance with applicable data protection law.